

Nombre: Rosa Mariana Torrez Quispe

El Dpto de T.I. de una empresa financiera, tiene más de 15 años en el mercado y como parte de la información recopilada de un estudio, se identificaron los siguientes puntos:

1. Se desarrolló un nuevo sistema de gestión que será utilizado en la institución, el cual tiene todas las medidas de seguridad correctas en criptografía, controles de accesos, tiempo de sesiones, bitácoras o tablas de auditoría.
2. Se cuenta con un equipamiento de última generación a nivel de servidores, unidades de almacenamiento y equipos de redes que están operando por 1 año.
- ☐ 3. Debido al volumen de información generada diariamente y para extender el espacio de almacenamiento, se decide deshabilitar las tablas de auditoría del sistema.
4. Se realizan backups con un esquema de 10 copias, mismas que son almacenadas a más de 25 km del CPD principal.
- ☐ 5. Como parte de un convenio interinstitucional, se reciben semestralmente 3 practicantes de informática, los cuales pueden llevar sus laptops y acceder a la red a partir de ellas para realizar las actividades que les soliciten.
- ☐ 6. Existe un firewall de red, donde se habilita el puerto 22 para el acceso remoto, habilitado únicamente para el responsable de redes y jefe de T.I. de la institución en caso de necesitar acceder los servidores.
- ☐ 7. Recientemente finalizó la licencia de antivirus de pago que se contrataba anualmente, y considerando que es una inversión elevada, se opta por utilizar la versión gratuita, ya que existen información importante almacenada en las computadoras que usan los funcionarios, toda información importante está en el servidor que usa una distribución Linux.
- ☐ 8. Debido a la necesidad de garantizar 24/7, se cancela por el servicio en la nube para tener el equipamiento virtualizado mínimo en caso de que el CDP sufra algún **desastre**.

Identificar los elementos que deban ser analizados siguiendo la metodología de 6 pasos.

Análisis de Riesgos para el Departamento de T.I. de la Empresa Financiera

- **Punto 3:** Deshabilitar las tablas de auditoría para extender el espacio de almacenamiento. Esto elimina el registro de actividades, lo que impide la detección de incidentes.
- **Punto 5:** Permitir que estudiantes internacionales traigan sus laptops y accedan a la red. Riesgo de introducción de malware o accesos no controlados.
- **Punto 6:** Firewall con puerto 22 (SSH) habilitado para el rango de la institución. Aunque SSH es seguro, si el rango IP es amplio o mal gestionado, podría permitir accesos no autorizados.
- **Punto 7:** Licencia de antivirus expirada, usando versión gratuita, asumiendo que Linux en el servidor es suficiente. Las versiones gratuitas pueden ser limitadas, y no protege adecuadamente contra amenazas en PCs.
- **Punto 8:** Cancelación del servicio en la nube para virtualización en caso de desastre. Elimina la redundancia para recuperación, exponiendo a fallos totales.

TAREAS

Seleccionar únicamente los puntos donde se pueda suscitar un incidente, identifique las amenazas, vulnerabilidades para poder hacer el análisis de riesgo siguiendo un enfoque metódico (utilizar los 6 pasos aprendidos en clase)

1. DETERMINAR EL ALCANCE

El alcance se centra en el Departamento de Informática de la empresa financiera T.I. y los procesos que se desarrollan en esa unidad, incluyendo sistemas de gestión, redes, seguridad y operaciones diarias.

2. IDENTIFICAR Y VALORAR LOS ACTIVOS

IDENTIFICACIÓN DE ACTIVOS

Basado en los puntos seleccionados, los activos relevantes son:

- **Dispositivos:** Servidores, unidades de almacenamiento, laptops de estudiantes.
- **Software y Aplicaciones:** Tablas de auditoría, aplicación de antivirus, sistema de gestión, servicio en la nube para virtualización.
- **Personal:** Responsable de redes, Jefe de T.I.
- **Telecomunicaciones:** Firewall, puerto 22 (SSH), Conexiones de acceso remoto
- **Instalaciones:** CPD (Centro de Procesamiento de Datos) principal

VALORACIÓN DE ACTIVOS		
Activo	Valoración	Importancia
Dispositivos	Servidores $D=5 + I=4 + C=4 \Rightarrow 13/3 = 4.33 \rightarrow 4$	Alta
	Unidades de almacenamiento $D=5 + I=4 + C=4 \Rightarrow 13/3 = 4.33 \rightarrow 4$	Alta
	Laptops de estudiantes $D=3 + I=3 + C=4 \Rightarrow 10/3 = 3.33 \rightarrow 3$	Media
Software y Aplicaciones	Tablas de auditoría $D=4 + I=5 + C=4 \Rightarrow 13/3 = 4.33 \rightarrow 4$	Alta
	Antivirus (versión gratuita) $D=4 + I=4 + C=3 \Rightarrow 11/3 = 3.67 \rightarrow 4$	Alta
	Sistema de gestión $D=5 + I=5 + C=5 \Rightarrow 15/3 = 5$	Muy Alta
	Servicio en la nube (virtualización) $D=5 + I=4 + C=3 \Rightarrow 12/3 = 4$	Alta
Personal	Responsable de redes $D=5 + I=3 + C=4 \Rightarrow 12/3 = 4$	Alta

ID_7	Responsable de redes	Administrador de la infraestructura de red	Administrador Red	Personal	Oficinas	Alta
ID_8	Jefe de T.I.	Supervisor de operaciones y seguridad TI	Jefe Dpto. TI	Personal	Oficinas	Alta
ID_9	Practicantes de informática (externos)	Usuarios temporales con acceso a red bajo convenio	Gerencia TI	Personal	Oficinas	Baja
TELECOMUNICACIONES						
ID_10	Firewall	Dispositivo de control de accesos a la red	Administrador Red	Telecom	Infraestructura	Alta
ID_11	Puerto 22 SSH	Protocolo para acceso remoto seguro	Administrador Red	Telecom	Infraestructura	Muy Alta
INSTALACIONES						
ID_12	CPD (Centro de Procesamiento de Datos) principal	Centro de datos principal de la institución	Jefe Seguridad	Inmueble	Edificio principal	Alta

4. IDENTIFICAR LAS AMENAZAS

Software y aplicaciones

- Debido al volumen de información generada diariamente y para extender el espacio de almacenamiento, se decide deshabilitar las tablas de auditoría del sistema. **ERRORES Y FALLOS NO INTENCIONADOS** -> escapes de información (I,C), destrucción de la información (D), fugas de información (C), errores de monitorización (log) (I) Las soluciones antivirus gratuitas tienen protección limitada: actualizaciones lentas, sin análisis avanzado, sin protección contra amenazas nuevas (zero-day). Los funcionarios usan computadoras con información importante que no estarán protegidas. Malware como spyware o troyanos bancarios no serán detectados, comprometiendo credenciales administrativas.
- Recientemente finalizó la licencia de antivirus de pago que se contrataba anualmente, y considerando que es una inversión elevada, se opta por utilizar la versión gratuita, ya que existen información importante almacenada en las computadoras que usan los funcionarios, toda información importante está en el servidor que usa una distribución Linux **ERRORES Y FALLOS NO**

INTENCIONADOS -> "Vulnerabilidades de los programas (software)"(D,I,C)
"Difusión de software dañino"(D,I,C)

TELECOMUNICACIONES

- Existe un firewall de red, donde se habilita el puerto 22 para el acceso remoto, habilitado únicamente para el responsable de redes y jefe de T.I. de la institución en caso de necesitar acceder los servidores **ATAQUES INTENCIONADOS** -> **Abuso de privilegios de acceso (D, I, C), Análisis de tráfico (C)**. Aunque SSH es seguro, si las credenciales de administradores se comprometen por phishing o ingeniería social, atacantes tienen acceso remoto a servidores críticos. Un administrador malintencionado podría modificar logs, exfiltrar datos o instalar backdoors. El análisis de tráfico SSH también revela información sobre la estructura de servidores.
- Como parte de un convenio interinstitucional, se reciben semestralmente 3 practicantes de informática, los cuales pueden llevar sus laptops y acceder a la red a partir de ellas para realizar las actividades que les soliciten. **ATAQUES INTENCIONADOS**-> **Acceso no autorizado (I, C), Difusión de software dañino (D, I, C)**. Las laptops personales no cumplen estándares de seguridad institucionales: sin antivirus, sin actualizaciones de seguridad, con permisos de usuario elevados. Un dispositivo infectado se convierte en punto de entrada al que atacantes pueden usar para propagar malware a toda la red, robar datos de clientes y acceder a sistemas críticos. Los practicantes no reciben capacitación en seguridad informática.

INSTALACIONES

Debido a la necesidad de garantizar 24/7, se cancela por el servicio en la nube para tener el equipamiento virtualizado mínimo en caso de que el CDP sufra algún desastre.

ERRORES Y FALLOS NO INTENCIONADOS -> **Caída del sistema por agotamiento de recursos(D), DESASTRES NATURALES** -> **fuego (Incendios) (D), Daños por agua (Inundaciones)(D)**.

Un único centro de datos es un punto único de fallo. Si ocurre incendio, inundación o corte de energía prolongado, toda la infraestructura colapsa. Una institución financiera tiene obligación legal de mantener servicios disponibles 24/7 incluso ante desastres. Los backups solo recuperan datos, no servicios activos. Sin cloud, no hay redundancia geográfica.

Software y aplicaciones

- Debido al volumen de información generada diariamente y para extender el espacio de almacenamiento, se decide deshabilitar las tablas de auditoría del sistema -> **AUSENCIA DE PISTAS DE AUDITORÍA**, para extender el espacio de almacenamiento, *se deshabilitaron las tablas de auditoría del sistema*. Esta acción elimina el registro de todas las operaciones, lo que representa una vulnerabilidad grave, ya que impide detectar modificaciones, accesos no autorizados o manipulaciones. La ausencia de bitácoras compromete la **integridad** y la **confidencialidad** de la información, impidiendo realizar análisis forenses en caso de incidentes.
- Recientemente finalizó la licencia de antivirus de pago que se contrataba anualmente, y considerando que es una inversión elevada, se opta por utilizar la versión gratuita, ya que existen información importante almacenada en las computadoras que usan los funcionarios, toda información importante está en el servidor que usa una distribución Linux. **DEFECTOS BIEN CONOCIDOS DE SOFTWARE**, *la licencia del antivirus de pago expiró* y se optó por una versión gratuita. Estas soluciones carecen de actualizaciones rápidas y defensa frente a amenazas nuevas. Esto expone a los equipos a malware, spyware o troyanos bancarios, que podrían robar credenciales administrativas o datos sensibles. Es una vulnerabilidad **técnica directa (D, I, C)** y también una **deficiencia en la gestión de seguridad**.

TELECOMUNICACIONES

- Existe un firewall de red, donde se habilita el puerto 22 para el acceso remoto, habilitado únicamente para el responsable de redes y jefe de T.I. de la institución en caso de necesitar acceder los servidores-> **AUSENCIA DE IDENTIFICACIÓN Y AUTENTICACIÓN DE EMISOR Y RECEPTOR** *el puerto 22 está habilitado para acceso remoto por el jefe de T.I. y el responsable de redes*. Aunque SSH es seguro, sin un control de IPs, doble autenticación o monitoreo continuo, existe riesgo de **abuso de privilegios y análisis de tráfico**. Si las credenciales se ven comprometidas por phishing o ingeniería social, se perdería el control total de los servidores críticos. Sin autenticación multifactor, si las credenciales de administradores se comprometen por phishing, atacantes tienen acceso remoto total a servidores. Pueden modificar logs, exfiltrar datos o instalar backdoors. El tráfico SSH revela información sobre la arquitectura de servidores.
- Como parte de un convenio interinstitucional, se reciben semestralmente 3 practicantes de informática, los cuales pueden llevar sus laptops y acceder a la red a partir de ellas para realizar las actividades que les soliciten. **LÍNEAS DE COMUNICACIÓN SIN PROTECCIÓN + TRÁFICO SENSIBLE SIN PROTECCIÓN**

- , los practicantes pueden conectar sus laptops personales a la red institucional sin cumplir estándares de seguridad. Estas computadoras no cuentan con antivirus ni actualizaciones, pudiendo ser portadoras de malware. Esto constituye una vulnerabilidad de tipo organizativa y técnica, ya que permite la **difusión de software dañino** y **acceso no autorizado** afectando a toda la red interna.

INSTALACIONES

- Debido a la necesidad de garantizar 24/7, se cancela por el servicio en la nube para tener el equipamiento virtualizado mínimo en caso de que el CDP sufra algún desastre. **RED ENERGÉTICA INESTABLE, UBICACIÓN EN ÁREA SUSCEPTIBLE DE INUNDACIÓN, AUSENCIA DE PROTECCIÓN FÍSICA.** *Un único centro de datos es punto único de fallo. Desastres naturales (incendio, inundación) o cortes de energía provocan colapso total. Una institución financiera debe mantener servicios 24/7. Los backups solo recuperan datos, no servicios activos. Sin cloud no hay redundancia geográfica ni recuperación ante desastres.*

EVALUAR EL RIESGO

$$\text{RIESGO} = \text{PROBABILIDAD} * \text{IMPACTO}$$

SOFTWARE Y APLICACIONES

Nº	Descripción del Riesgo	Probabilidad	Impacto			Total	Riesgo
			Financiero	Imagen			
1	Deshabilitación de tablas de auditoría impide detectar incidentes, manipulación de datos o accesos no autorizados.	4	4	4	5	17.33	Alto
2	Antivirus gratuito sin protección avanzada permite ingreso de malware y robo de credenciales administrativas.	4	4	4	4	16.00	Alto

(Software y Aplicaciones): 16.67 → Nivel: Alto

Cálculos

$$\text{Impacto} = 4 + 4 + 5 = 13 \rightarrow 13/3 = 4.33$$

$$\text{Riesgo} = 4 \times 4.33 = 17.33$$

$$\text{Impacto} = 4 + 4 + 4 = 12 \rightarrow 12/3 = 4.00$$

$$\text{Riesgo} = 4 \times 4.00 = 16.00$$

$$(17.33 + 16.00)/2 = 16.67$$

TELECOMUNICACIONES

Nº	Descripción del Riesgo	Probabilidad	Impacto			Total	Riesgo
			Financiero	Imagen			
3	Puerto 22 SSH habilitado puede ser comprometido mediante robo de credenciales o abuso de privilegios.	4	4	5	5	18.67	Muy Alto
4	Laptops personales conectadas a la red pueden propagar malware o permitir accesos no controlados.	4	4	4	5	17.33	Alto

Cálculos

$$\text{Impacto} = 4 + 5 + 5 = 14 \rightarrow 14/3 = 4.67$$

$$\text{Riesgo} = 4 \times 4.67 = 18.67$$

$$\text{Impacto} = 4 + 4 + 5 = 13 \rightarrow 13/3 = 4.33$$

$$\text{Riesgo} = 4 \times 4.33 = 17.33$$

$$(18.67 + 17.33)/2 = 18.00$$

INSTALACIONES

Nº	Descripción del Riesgo	Probabilidad	Impacto			Total	Riesgo
			Financiero	Imagen			
5	Eliminación del servicio en la nube provoca pérdida total de operación ante desastres o fallas del CPD.	3	4	4	5	13.00	Medio-Alto

Cálculos

$$Impacto = 4 + 4 + 5 = 13 \rightarrow 13/3 = 4.33$$

$$Riesgo = 3 \times 4.33 = 13.00$$

Nº	Descripción del Riesgo	Probabilidad	Impacto	Activo Afectado
1	Deshabilitación de tablas de auditoría impide detectar incidentes, accesos no autorizados o alteraciones de datos.	4	4	Software y Aplicaciones
2	Uso de antivirus gratuito sin protección avanzada puede permitir infecciones por malware o robo de credenciales.	4	4	Software y Aplicaciones
3	Puerto 22 (SSH) habilitado para acceso remoto podría ser explotado por robo de credenciales o abuso de privilegios.	4	5	Telecomunicaciones
4	Conexión de laptops personales a la red institucional sin medidas de seguridad puede introducir malware o accesos indebidos.	4	4	Telecomunicaciones
5	Cancelación del servicio en la nube elimina la redundancia y recuperación ante desastres del CPD principal.	3	4	Instalaciones

MATRIZ DE RIESGO

Muy Alto (5)	Medio	Medio	5	3	Muy Alto
Alto (4)	Bajo	Medio	Alto	(1,2,4)	Muy Alto
Medio (3)	Muy Bajo	Bajo	Medio (4)	Alto	Alto
Bajo (2)	Muy Bajo	Bajo	Bajo	Medio	Medio
Muy Bajo (1)	Muy Bajo	Muy Bajo	Muy Bajo	Bajo	Medio
Impacto	Muy Bajo (1)	Bajo (2)	Medio (3)	Alto (4)	Muy Alto (5)

probabilidad

TRATAMIENTO DE RIESGOS

ACTIVO	RIESGO IDENTIFICADO	CONTRAMEDIDA PROPUESTA
SOFTWARE Y APLICACIONES	Deshabilitación de las tablas de auditoría impide la detección de accesos no autorizados, manipulación de datos o incidentes internos.	Rehabilitar las tablas de auditoría con rotación automática de logs y almacenamiento externo. Implementar monitoreo SIEM para análisis continuo y detección temprana de anomalías.
SOFTWARE Y APLICACIONES	Uso de antivirus gratuito con protección limitada frente a amenazas avanzadas.	Implementar una solución antivirus corporativa o EDR (Endpoint Detection and Response) con administración centralizada, políticas de actualización automática y protección contra amenazas de tipo zero-day.
TELECOMUNICACIONES	Puerto 22 (SSH) habilitado sin controles reforzados puede ser explotado por robo de credenciales o abuso de privilegios administrativos.	Restringir el acceso SSH únicamente a direcciones IP autorizadas, habilitar autenticación multifactor (MFA) , rotar claves periódicamente y registrar todas las sesiones en un sistema de auditoría.
TELECOMUNICACIONES	Conexión de laptops personales de practicantes	Crear una VLAN de invitados separada de la red institucional, exigir antivirus actualizado y

	a la red interna sin controles de seguridad.	escaneo previo antes del acceso. Aplicar políticas BYOD y capacitaciones básicas en seguridad.
INSTALACIONES	Cancelación del servicio en la nube elimina la redundancia ante desastres o fallas del CPD principal.	Reactivar la infraestructura en la nube o implementar replicación geográfica , con respaldo incremental diario y simulacros de recuperación. Esto garantiza continuidad operativa 24/7.